

Checklist

Microsoft Windows Infrastructure Security

1. Windows Endpoint and Server Hygiene

- ☐ Upgrade unsupported Windows operating systems to currently supported versions.
- ☐ Identify systems that cannot be upgraded because of legacy or vendor-dependent applications.
- ☐ Remove unsupported legacy systems from the network whenever possible.
- ☐ If legacy systems must remain online, isolate them on dedicated VLANs or an appropriately air-gapped network.
- ☐ Document the business risk associated with keeping unsupported operating systems.
- ☐ Communicate legacy-system risks to relevant business and technical stakeholders.
- ☐ Maintain a plan for eventual replacement or migration of outdated systems.

2. Patch and Software Management

- ☐ Use a centralized software-update platform such as WSUS, Configuration Manager, or another approved patch-management solution.
- ☐ Apply Microsoft Windows security updates promptly.
- ☐ Patch commonly exploited third-party software such as browsers, Java, and PDF applications.
- ☐ Maintain an accurate inventory of installed software.
- ☐ Remove software that is unnecessary for business operations.
- ☐ Track systems or applications that cannot be patched normally.
- ☐ Establish compensating security controls for software that must remain outdated.

3. SMB Shares and File Sharing

- ☐ Inventory SMB/file shares throughout the environment.
- ☐ Scan for unexpectedly open or exposed shares using approved administrative or security tools.
- ☐ Review each share for sensitive information, credentials, trade secrets, PII, or other restricted data.
- ☐ Remove unnecessary shares.
- ☐ Restrict share permissions to only the users and groups that require access.
- ☐ Review both share permissions and NTFS permissions.
- ☐ Periodically re-audit file shares for excessive access.

4. Active Directory Forest Design

- ☐ Treat the Active Directory forest as a major security boundary.
- ☐ Review the number of forests in the organization and confirm that each is necessary.
- ☐ Document every cross-forest trust.
- ☐ Document every cross-domain trust.
- ☐ Ensure stakeholders understand the security risks introduced by trusts.
- ☐ Remove trusts that are no longer required.
- ☐ Use one-way trusts where appropriate rather than granting unnecessary bidirectional access.
- ☐ Use SID filtering where appropriate.
- ☐ Use selective authentication when stronger trust restrictions are needed.
- ☐ Apply appropriate authentication controls to hybrid or cloud-connected directory environments.

5. Active Directory Domains

- ☐ Do not treat an individual domain as a true security boundary.
- ☐ Design domains primarily as structural and administrative containers.
- ☐ Assume directory information can be queried by authenticated domain accounts.
- ☐ Avoid relying on domain separation alone to protect highly sensitive information.
- ☐ Review domain structure periodically as the organization changes.

6. Domain Controllers

- ☐ Treat domain controllers as high-value security assets.
- ☐ Prevent domain controllers from being used as ordinary workstations.
- ☐ Do not use domain controllers as general-purpose or dual-purpose servers.
- ☐ Restrict physical access to domain controllers.
- ☐ Place physical domain controllers in dedicated secure racks, cages, or equivalent protected locations.
- ☐ Use TPM capabilities where supported.
- ☐ Protect domain-controller storage with appropriate drive encryption.
- ☐ Restrict interactive logons to domain controllers.
- ☐ Limit administrative access to authorized personnel.
- ☐ Have a documented response and recovery plan for a compromised domain controller.
- ☐ Understand that rebuilding or recovering the forest may be necessary after serious domain-controller compromise.
- ☐ Consider read-only domain controllers for remote or less physically secure locations.
- ☐ Physically secure offsite domain controllers even when they are read-only.

7. FSMO Role Placement

- ☐ Document which servers hold each FSMO role.
- ☐ Keep the PDC Emulator and RID Master roles appropriately placed according to the environment's design.
- ☐ Consider the workload placed on the PDC Emulator when selecting its host.
- ☐ Avoid placing the Infrastructure Master on a Global Catalog server unless the forest/domain design makes this appropriate.
- ☐ Place the Schema Master and Domain Naming Master appropriately within the forest.
- ☐ Review FSMO placement after infrastructure changes or migrations.
- ☐ Maintain procedures for transferring or seizing FSMO roles during recovery.

8. Organizational Units

- ☐ Design OUs around clear administrative and policy requirements.
- ☐ Use OUs to delegate administrative rights at the appropriate scope.
- ☐ Avoid unnecessary OU complexity.
- ☐ Align OU structure with Group Policy requirements.
- ☐ Review delegated permissions on OUs.

- ☐ Remove obsolete OUs and delegated privileges.

9. Active Directory Groups

- ☐ Place users into global groups rather than assigning permissions directly to individual users.
- ☐ Place global groups into domain local groups where appropriate.
- ☐ Assign domain local groups to resource access-control lists.
- ☐ For multi-domain environments, place global groups into universal groups when required.
- ☐ Place universal groups into domain local groups.
- ☐ Assign domain local groups to the resource ACLs.
- ☐ Avoid excessive or unnecessarily complicated nested groups.
- ☐ Regularly review group membership.
- ☐ Remove stale or unresolved SIDs.
- ☐ Investigate tools such as SIDWalk when cleaning up unresolved SID references.

10. Privileged Accounts

- ☐ Minimize membership in the Domain Admins group.
- ☐ Review membership in all other privileged administrative groups.
- ☐ Remove users who do not require permanent administrative privileges.
- ☐ Avoid granting administrator-level access simply because an application is easier to operate that way.
- ☐ Determine the exact permissions required by each application or administrative task.
- ☐ Delegate only the minimum required permissions.
- ☐ Review privileged access regularly.
- ☐ Log and monitor privileged administrative activity.
- ☐ Maintain separate administrative and normal-user accounts where appropriate.

11. Service Accounts

- ☐ Use dedicated service accounts for services and applications.
- ☐ Prevent service accounts from being used for normal interactive logons.
- ☐ Apply least privilege to service accounts.
- ☐ Use a consistent service-account naming convention.
- ☐ Document the service or application associated with each service account.

- ☐ Monitor service-account activity.
- ☐ Review service-account permissions periodically.
- ☐ Remove service accounts that are no longer required.

12. Local Administrator Accounts

- ☐ Avoid using the same local administrator password across multiple endpoints.
- ☐ Deploy Microsoft LAPS or an equivalent approved solution.
- ☐ Use unique, randomized local administrator passwords.
- ☐ Restrict who can retrieve managed local administrator passwords.
- ☐ Audit use of local administrator credentials.
- ☐ Review systems that are exempt from centralized local-password management.

13. Shared Accounts

- ☐ Eliminate shared user accounts wherever possible.
- ☐ Require users and administrators to authenticate with individually attributable accounts.
- ☐ Replace shared administrator accounts with named administrative identities.
- ☐ Document any unavoidable shared accounts and their business justification.
- ☐ Closely monitor use of any approved shared accounts.
- ☐ Periodically review whether exceptions are still necessary.

14. Group Policy Objects

- ☐ Use Group Policy to centrally enforce Windows security settings.
- ☐ Maintain a clear and consistent GPO naming standard.
- ☐ Document what each GPO does.
- ☐ Understand GPO inheritance and processing order.
- ☐ Minimize unnecessary or conflicting GPOs.
- ☐ Test GPO changes before broad deployment.
- ☐ Review GPO permissions and delegation.
- ☐ Restrict who can create, modify, link, and delete GPOs.
- ☐ Use recognized security baselines, such as applicable NIST or Microsoft recommendations, as a starting point.
- ☐ Include core baseline security settings in local policy where useful so protections remain when a computer is temporarily outside normal domain policy.
- ☐ Disable unnecessary legacy protocols and weak settings through policy.

- ☐ Apply appropriate account, password, auditing, and access-control requirements through policy.
- ☐ Regularly audit GPOs for obsolete or duplicate settings.

15. Default Computer and User Placement

- ☐ Avoid leaving newly joined computers unmanaged in default containers longer than necessary.
- ☐ Create controlled OUs for newly joined computers.
- ☐ Redirect newly created computer objects to the appropriate managed OU where suitable.
- ☐ Apply baseline GPOs immediately to newly joined systems.
- ☐ Establish a controlled process for administrators installing or joining new systems.
- ☐ Verify new systems appear in the intended OU and receive the correct policies.

16. Monitoring and Auditing

- ☐ Enable appropriate Windows and Active Directory security logging.
- ☐ Collect important logs centrally.
- ☐ Monitor privileged account activity.
- ☐ Monitor changes to privileged groups.
- ☐ Monitor unusual authentication behavior.
- ☐ Monitor changes to trusts.
- ☐ Monitor changes to GPOs.
- ☐ Monitor service-account activity.
- ☐ Monitor unusual SMB/share access.
- ☐ Regularly review logs rather than collecting them without analysis.

17. Physical and Recovery Security

- ☐ Restrict physical access to critical Windows infrastructure.
- ☐ Document procedures for responding to domain-controller compromise.
- ☐ Maintain tested backups of Active Directory and critical Windows systems.
- ☐ Test restoration procedures regularly.
- ☐ Ensure recovery procedures account for compromise of privileged credentials.
- ☐ Protect backup systems from ordinary administrative compromise.
- ☐ Maintain current network and Active Directory architecture documentation.

Final Review

- ☐ No unsupported Windows systems remain without an approved exception.
- ☐ All unavoidable legacy systems are appropriately isolated.
- ☐ Windows and third-party patching is centrally managed.
- ☐ Unnecessary SMB shares have been removed.
- ☐ Active Directory trusts are documented and minimized.
- ☐ Domain controllers are dedicated and physically secured.
- ☐ FSMO role placement is documented and appropriate.
- ☐ OU delegation follows least privilege.
- ☐ Group nesting follows a consistent model.
- ☐ Domain Admin and other privileged memberships are minimized.
- ☐ Service accounts are dedicated, restricted, and monitored.
- ☐ Local administrator passwords are uniquely managed with LAPS or an equivalent solution.
- ☐ Shared accounts have been eliminated wherever possible.
- ☐ Security baselines are enforced through Group Policy.
- ☐ Newly joined systems automatically receive appropriate policies.
- ☐ Logging, monitoring, backup, and recovery processes have been tested.